

Materia

Seguridad en el desarrollo de Aplicaciones

Nombre

Ricardo Porras Reyes

Matricula

2024171008

Grupo

IDSG17

Profesor

Gerardo Ramírez Villarreal

Instrumentación de Controladores

Resumen de Criterios de Instrumentación

Cada acción en los controladores fue modificada para registrar de manera estructurada:

- **Entrada y Salida:** Mensajes explícitos al inicio y fin de la acción.
- **Métricas:** Medición exacta del tiempo de ejecución mediante Stopwatch en milisegundos (ElapsedMs).
- **Contexto:** Captura automatizada de Usuario (Sesión) e IP de origen.
- **Seguridad:** Omisión estricta del campo password en el controlador de autenticación.
- **Manejo de Estados:** Registro de Warnings ante datos anómalos y Errors/Excepciones mediante bloques try-catch-finally.

ID	Controlador	Acción / Entrada	Tipo de Log Esperado	Estado
1	HomeController	Acceso a Index / Privacy	Information (Inicio y Fin)	Funcional
2	AuthController	Intento de Login (Fallido)	Warning (Evento Autenticación)	Funcional
3	AuthController	Login Exitoso + Exclusión Pass	Information (Muestra User/IP, no clave)	Funcional
4	SearchController	Búsqueda Vacía	Warning (Parámetro vacío)	Funcional
5	SearchController	Búsqueda con "error_test"	Error (Excepción controlada)	Funcional
6	CommentController	Comentario con <script>	Warning (Alerta potencial XSS)	Funcional

7	ApiController	Petición IDOR (ID ajeno)	Warning (Acceso denegado/Forbid)	Funcional
---	---------------	--------------------------	----------------------------------	-----------

Matriz de Pruebas Ejecutadas Evidencias de Monitoreo en Seq

Evidencia 1: Trazabilidad Completa (Flujo Feliz)

- **Filtro en Seq:** SourceContext = 'HomeController' o SourceContext = 'CommentController'
- **Descripción:** Demostración de los eventos de inicio y fin, mostrando el usuario, la IP y el tiempo de ejecución en milisegundos (ElapsedMs).

02 Jul 2026 15:30:23.172	Fin Ejecución Auth.Login [POST]. Tiempo de ejecución:2715ms
02 Jul 2026 15:30:23.168	Evento Autenticación - ÉXITO. Usuario:admin ha iniciado sesión correctamente desde IP:::1
02 Jul 2026 15:30:23.156	Inicio Auth.Login [POST]. Evento Autenticación - Intento de acceso para Usuario:admin IP:::1
02 Jul 2026 15:30:20.456	Inicio Auth.Login [POST]. Evento Autenticación - Intento de acceso para Usuario:admin IP:::1
02 Jul 2026 15:29:37.408	Inicio Auth.Login [GET]. Usuario:Anónimo IP:::1
02 Jul 2026 15:29:26.963	Fin Ejecución Home.Index. Tiempo de ejecución:19ms
02 Jul 2026 15:29:26.960	Fin Home.Index - Renderizando vista principal.
02 Jul 2026 15:29:26.955	Inicio Home.Index. Usuario:Anónimo IP:::1

Evidencia 2: Eventos de Autenticación y Desarrollo Seguro

- **Filtro en Seq:** SourceContext = 'AuthController'
- **Descripción:** Validación de que se registran los éxitos y fallos de autenticación. Se expande el detalle del log para demostrar visualmente que **no se almacena ni se expone la contraseña** en las propiedades estructuradas.

02 Jul 2026 15:30:23.629	Fin Auth.Dashboard - Carga exitosa del modelo para Usuario:admin
Event ☐ Level (Information) ☐ Type (0x55E90A36) ☐ Trace (c227...) ☐ Export ☐	
✓ x	ActionId 18043a42-a103-4247-9877-5af0fd3240b1
✓ x	ActionName VulnerableApp.Controllers.AuthController.Dashboard (VulnerableApp)
✓ x	ConnectionId 0HNMOG302171U
✓ x	RequestId 0HNMOG302171U:00000002
✓ x	RequestPath /Auth/Dashboard
✓ x	SourceContext VulnerableApp.Controllers.AuthController
✓ x	ThreadId 15
✓ x	User admin
02 Jul 2026 15:30:23.474	Inicio Auth.Dashboard. Usuario:admin IP:::1
Event ☐ Level (Information) ☐ Type (0xB0A6AA6F) ☐ Trace (c227...) ☐ Export ☐	
✓ x	ActionId 18043a42-a103-4247-9877-5af0fd3240b1
✓ x	ActionName VulnerableApp.Controllers.AuthController.Dashboard (VulnerableApp)
✓ x	ConnectionId 0HNMOG302171U
✓ x	IP :::1
✓ x	RequestId 0HNMOG302171U:00000002
✓ x	RequestPath /Auth/Dashboard
✓ x	SourceContext VulnerableApp.Controllers.AuthController
✓ x	ThreadId 15
✓ x	User admin

Evidencia 3: Registro de Advertencias (Warnings) - Filtro de Inyección XSS

- **Filtro en Seq:** @Level = 'Warning' and SourceContext = 'CommentController'

- **Descripción:** Captura tras enviar el payload <script> en la caja de comentarios, demostrando que la aplicación detecta la anomalía y emite un Warning preventivo.

02 Jul 2026 15:32:04.326	●	Comment.AddComment - Alerta de posible XSS detectado en parámetro 'comment' por Usuario:admin		
Event	Level (Warning)	Type (0x62320D77)	Trace (0f19...)	Export
✓ x	ActionId	add38a4-e5f7-4137-992b-debbfa8371f2		
✓ x	ActionName	VulnerableApp.Controllers.CommentController.AddComment (VulnerableApp)		
✓ x	ConnectionId	0HNM0G302171U		
✓ x	RequestId	0HNM0G302171U:00000008		
✓ x	RequestPath	/Comment/AddComment		
✓ x	SourceContext	VulnerableApp.Controllers.CommentController		
✓ x	ThreadId	19		
✓ x	User	admin		

Evidencia 4: Registro de Excepciones y Errores

- **Filtro en Seq: @Level = 'Error'**
- **Descripción:** Captura del error crítico generado al buscar "error_test". Muestra la captura del log de nivel Error junto con el rastreo de la pila (*Stack Trace*) de la excepción.

02 Jul 2026 15:42:45.702

● Excepción capturada en Search.Index al buscar: error_test

Event	Level (Error)	Type (0x120CC79D)	Trace (b88e...)	Export
✓ x	ActionId	d0db587c-0ff6-4a43-9af6-11c5c3cf4549		
✓ x	ActionName	VulnerableApp.Controllers.SearchController.Index (VulnerableApp)		
✓ x	ConnectionId	0HNM0G3021721		
✓ x	RequestId	0HNM0G3021721:00000003		
✓ x	RequestPath	/Search/Index		
✓ x	SearchParam	error_test		
✓ x	SourceContext	VulnerableApp.Controllers.SearchController		
✓ x	ThreadId	21		

System.InvalidOperationException: Simulación de error en la consulta a la base de datos de búsqueda.
at VulnerableApp.Controllers.SearchController.Index(String search) in C:\Users\porra\source\repos\VulnerableApp\Controllers\SearchController.cs:line 45

Conclusiones de Desarrollo Seguro

1. **No repudio y trazabilidad:** Al registrar la IP y el usuario en cada interacción, se tiene certeza de quién y desde dónde se ejecutan las operaciones.
2. **Defensa contra la fuga de datos:** La exclusión explícita de variables como password en los parámetros de _logger previene que información crítica termine almacenada en texto plano en repositorios de logs centralizados.
3. **Mantenimiento proactivo:** El uso de niveles como Warning para inputs sospechosos (como el payload de script) permite mitigar vectores de ataque antes de que se conviertan en incidentes reales.